

Northgate University

Cryptographic Policy

An ISO/IEC 27001:2013 aligned document · Internal Use Only

Document Reference	NGU-POL-10.1
Version	1.0
Classification	Internal Use Only
Issue Date	01 June 2026
Policy Owner	Chief Information Security Officer
Approved By	Information Governance Board
Next Review Date	01 June 2027
Aligned Standard	ISO/IEC 27001:2013 — Annex A.10 (A.10.1.1, A.10.1.2)

1. Purpose

This policy establishes how Northgate University ("the University") uses cryptographic controls to protect the confidentiality, integrity and authenticity of its information, and how cryptographic keys are managed throughout their life cycle, in line with ISO/IEC 27001:2013 Annex A.10.

2. Scope

This policy applies to all University information that requires cryptographic protection, and to all staff, students, contractors, third parties and systems that store, process or transmit such information — on University premises or remotely, using University-provided or personal equipment.

3. General Principles

- Cryptographic protection is applied on the basis of information classification and assessed risk (see Information Classification Policy, NGU-POL-8.2).
- Only approved algorithms, protocols and key lengths may be used; deprecated or unvetted cryptography must not be used.
- Cryptographic keys are treated as sensitive assets and managed under defined controls.
- Cryptography supports, but does not replace, other security controls such as access control and secure configuration.
- Use of cryptography complies with applicable legal, regulatory and contractual requirements.

4. When Cryptography Must Be Applied

Cryptographic controls must be applied in at least the following scenarios:

Scenario	Requirement
Confidential / Restricted data at rest	Encrypt using approved standards (e.g., database, file or volume encryption).
Data in transit over untrusted networks	Encrypt in transit using TLS or an approved VPN.
Laptops and mobile devices	Full-disk encryption enabled (see Remote Working Policy, NGU-POL-6.2).
Removable media holding non-public data	Encrypt the media; avoid use where alternatives exist.
Authentication secrets / passwords	Store using approved salted hashing; never store or transmit in plaintext.
Backups of Confidential information	Encrypt backups at rest and in transit.
Confidential email / files sent externally	Encrypt or use an approved secure transfer method.

5. Approved Cryptographic Standards

The following minimum standards apply (A.10.1.1). Standards are reviewed periodically and updated as guidance evolves:

Use	Approved Standard (minimum)
Symmetric encryption	AES — 256-bit (128-bit minimum) in a secure mode of operation.
Asymmetric encryption	RSA 2048-bit minimum, or ECC (e.g., P-256) or stronger.
Hashing / integrity	SHA-256 or stronger (SHA-2 / SHA-3 family).
Password storage	Salted, computationally hard hashing (bcrypt, scrypt, Argon2 or PBKDF2).
Transport security	TLS 1.2 minimum (TLS 1.3 preferred) with strong cipher suites.
Full-disk encryption	AES-256 (e.g., BitLocker, FileVault) on laptops and mobile devices.
VPN / remote access	IPsec or TLS-based VPN with strong, current ciphers.

6. Prohibited and Deprecated Cryptography

- DES and 3DES where deprecated for the use in question.
- MD5 and SHA-1 for security purposes.
- SSL (all versions) and TLS 1.0 / 1.1.
- Proprietary, unvetted or “home-grown” cryptographic algorithms.
- Hard-coded, shared or unmanaged keys and credentials.

7. Key Management

Cryptographic keys must be managed throughout their life cycle in accordance with ISO/IEC 27001:2013 A.10.1.2:

- Keys are generated using approved methods and adequate key lengths.
- Keys are stored securely and protected from unauthorised access (e.g., key vaults or hardware security modules where appropriate).
- Access to keys is restricted on a need-to-know basis, with separation of duties for critical key operations.
- Keys are rotated at defined intervals and whenever compromise is suspected.
- Keys are revoked and securely destroyed at the end of their life.
- Key recovery or escrow arrangements are established where loss of keys would threaten the availability of important information.
- Suspected or actual key compromise is reported and handled as a security incident (see Information Security Incident Management Policy, NGU-POL-16.1).

8. Certificate Management

- Digital certificates are obtained from trusted certificate authorities for external or production use.
- Certificates are tracked and renewed before expiry to avoid service disruption.
- Private keys associated with certificates are protected to the same standard as other cryptographic keys.

9. Data at Rest and in Transit

- Confidential and Restricted information is encrypted at rest using approved standards.
- Confidential information transmitted over untrusted networks is encrypted in transit using TLS or an approved VPN.
- Endpoint devices used for University work apply full-disk encryption (see Remote Working Policy, NGU-POL-6.2).

10. Roles and Responsibilities

- **Chief Information Security Officer (CISO).** Owns this policy and approves cryptographic standards and key-management requirements.
- **IT Service.** Implements and operates cryptographic controls, key management and certificate management.
- **Information Asset Owners (IAOs).** Determine cryptographic protection requirements for their information assets based on classification and risk.
- **All users.** Use only approved cryptographic controls and protect keys, credentials and encrypted information.

11. Legal and Regulatory Considerations

Encryption is used as a technical safeguard for personal data in line with the UK GDPR (Article 32) and the Data Protection Act 2018. The University also takes account of any lawful-access and export-control obligations relevant to cryptographic technology.

12. Compliance and Enforcement

Compliance with this policy is mandatory. Use of unauthorised cryptography, or failure to protect cryptographic keys and encrypted information, may result in disciplinary action and, for third parties, may constitute a breach of contract.

13. Related Policies and Standards

- Information Security Policy (NGU-POL-5.1)
- Information Classification Policy (NGU-POL-8.2)
- Access Control Policy (NGU-POL-9.1)
- Remote Working Policy (NGU-POL-6.2)
- Information Security Incident Management Policy (NGU-POL-16.1)
- ISO/IEC 27001:2013 — Annex A.10 (A.10.1.1 Policy on the use of cryptographic controls; A.10.1.2 Key management)
- UK GDPR (Article 32) and Data Protection Act 2018

14. Document Version History

Version	Date	Author	Summary of Change
1.0	01 June 2026	Chief Information Security Officer	Initial issue. Establishes cryptographic control and key-management requirements.